

Enterprise AI Authentication Research • Part 1 of 7

Part 1

Industry Survey

How leading AI platforms implement secure enterprise integrations

Enterprise Authentication & Identity Propagation for AI Agents

Overview

This section surveys ten leading enterprise AI platforms and examines how each implements authentication, authorization, connector models, identity propagation, session handling, token management, governance, audit logging, and multi-tenant isolation. Understanding these patterns is foundational before designing any production-grade AI integration.

Platforms Covered

- Google Gemini
- Claude (Anthropic)
- ChatGPT Enterprise (OpenAI)
- Microsoft 365 Copilot
- GitHub Copilot
- Amazon Q Business
- Atlassian Rovo
- ServiceNow AI Agents
- Glean
- Moveworks

1. Google Gemini

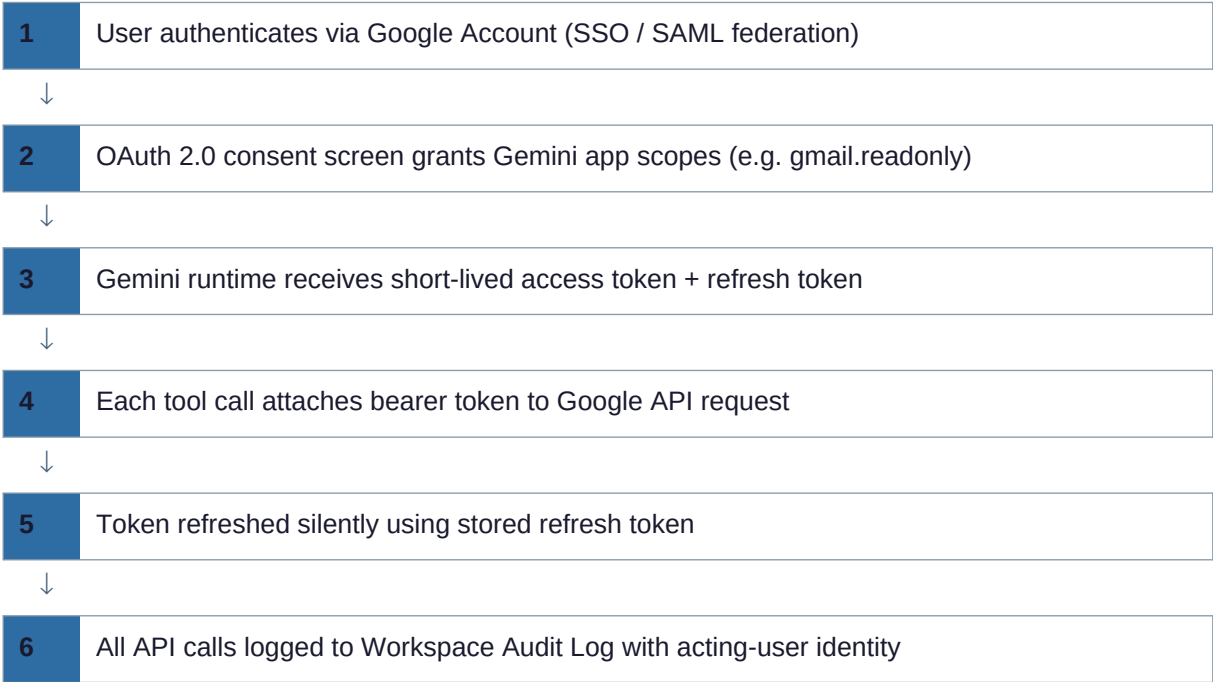
Google Gemini for Workspace integrates natively with Google's identity stack. Authentication is rooted in Google Cloud Identity / Workspace Directory, leveraging the same OAuth 2.0 consent flow a user performs when granting a third-party app access to their Workspace data.

Google Gemini — Architecture Matrix

Dimension	Detail
Architecture	SaaS, multi-tenant; dedicated VPC for Enterprise; data processed in Google infrastructure
Authentication	Google Account SSO → OAuth 2.0 with PKCE; supports SAML federation via Cloud Identity
Authorization	Google Workspace Admin policies; scoped OAuth consent; DLP enforced at API layer
Connector Model	Native Google Workspace connectors + Vertex AI extensions for third-party tools
Identity Propagation	Google-issued access token carries user sub claim; passed as bearer token to Google APIs
Session Handling	Google session cookies (SAPISID, SSID); refresh tokens stored server-side in Google Accounts

Dimension	Detail
Token Management	Short-lived access tokens (1 h); offline refresh tokens with rotation; CAE supported
Governance	Admin Console policies; Context-Aware Access; BeyondCorp enforcement
Audit Logging	Google Workspace Audit & Investigation tool; logs streamed to Cloud Logging / Chronicle
Multi-Tenant Isolation	Organisation-level data isolation; Workspace Customer ID scoping; VPC Service Controls

Gemini Authentication Flow



2. Claude — Anthropic

Claude is available via [claude.ai](#) (consumer / Teams), the Claude API, and Claude for Enterprise. Claude for Enterprise supports SSO via SAML 2.0 and SCIM provisioning. MCP (Model Context Protocol) is Anthropic's open protocol for tool integrations, enabling Claude to connect to enterprise data sources through a standardised server interface.

Claude — Architecture Matrix

Dimension	Detail
Architecture	Hosted SaaS; API-first; MCP servers deployed in customer infrastructure or Anthropic-hosted

Dimension	Detail
Authentication	SAML 2.0 SSO (Okta, Entra ID, Ping); SCIM provisioning; API key for programmatic access
Authorization	Admin-configurable tool permissions; MCP server enforces its own authz; no elevation by design
Connector Model	MCP (Model Context Protocol) — open standard; connectors are MCP servers exposing tool schemas
Identity Propagation	MCP server receives user context via HTTP headers or JWT; each MCP call can carry user identity
Session Handling	Web session via browser cookie; API sessions stateless per request; conversation context in prompt
Token Management	API keys long-lived; OAuth tokens managed by MCP server; Anthropic does not store third-party tokens
Governance	Enterprise policy controls (tool allow-list, data retention); Admin API for user management
Audit Logging	Admin audit log for user/admin actions; MCP server responsible for tool-level audit
Multi-Tenant Isolation	Organisation-scoped API keys; workspace isolation; SCIM-managed user directories

MCP Identity Flow

When Claude invokes an MCP tool, the MCP server is responsible for authenticating the call. Anthropic recommends that MCP servers validate the user identity header injected by the Claude platform, then exchange it for the user's own OAuth token via an On-Behalf-Of (OBO) pattern before calling downstream APIs. This ensures the downstream API always sees the end-user's identity, not a service account.

Key MCP Security Principles

- MCP servers MUST NOT accept arbitrary tool calls without validating caller identity
- User identity propagation via signed JWT or MCP authorization header
- MCP servers enforce least-privilege scopes independently of Claude
- All tool invocations should be logged with correlation to conversation ID
- Anthropic publishes the MCP specification at modelcontextprotocol.io

3. ChatGPT Enterprise — OpenAI

ChatGPT Enterprise provides SSO, data encryption, audit logs, and a no-training commitment. GPT Actions extend the model with OAuth-protected API integrations. The Responses API and Assistants API add stateful session management for production agent deployments.

ChatGPT Enterprise — Architecture Matrix

Dimension	Detail
Architecture	Hosted SaaS; Enterprise dedicated deployment option; data processed in OpenAI infrastructure
Authentication	SAML 2.0 SSO; SCIM provisioning; Service Accounts for automation
Authorization	Workspace admin controls; GPT Action-level OAuth scope configuration; no RAG data sharing cross-org
Connector Model	GPT Actions (OpenAPI schema + OAuth); Assistants API function calling; Responses API tools
Identity Propagation	GPT Action OAuth: user consent issues user's own token to Action; OpenAI passes it to API
Session Handling	Browser session (HttpOnly cookies); Assistants API thread IDs for stateful conversations
Token Management	OAuth tokens for Actions stored encrypted by OpenAI; short-lived access tokens with refresh
Governance	Admin dashboard; workspace-level GPT publishing controls; data residency options
Audit Logging	Admin audit log (user logins, GPT usage); exportable; retention configurable
Multi-Tenant Isolation	Workspace-scoped data; enterprise storage separate from consumer; no cross-workspace data

4. Microsoft 365 Copilot

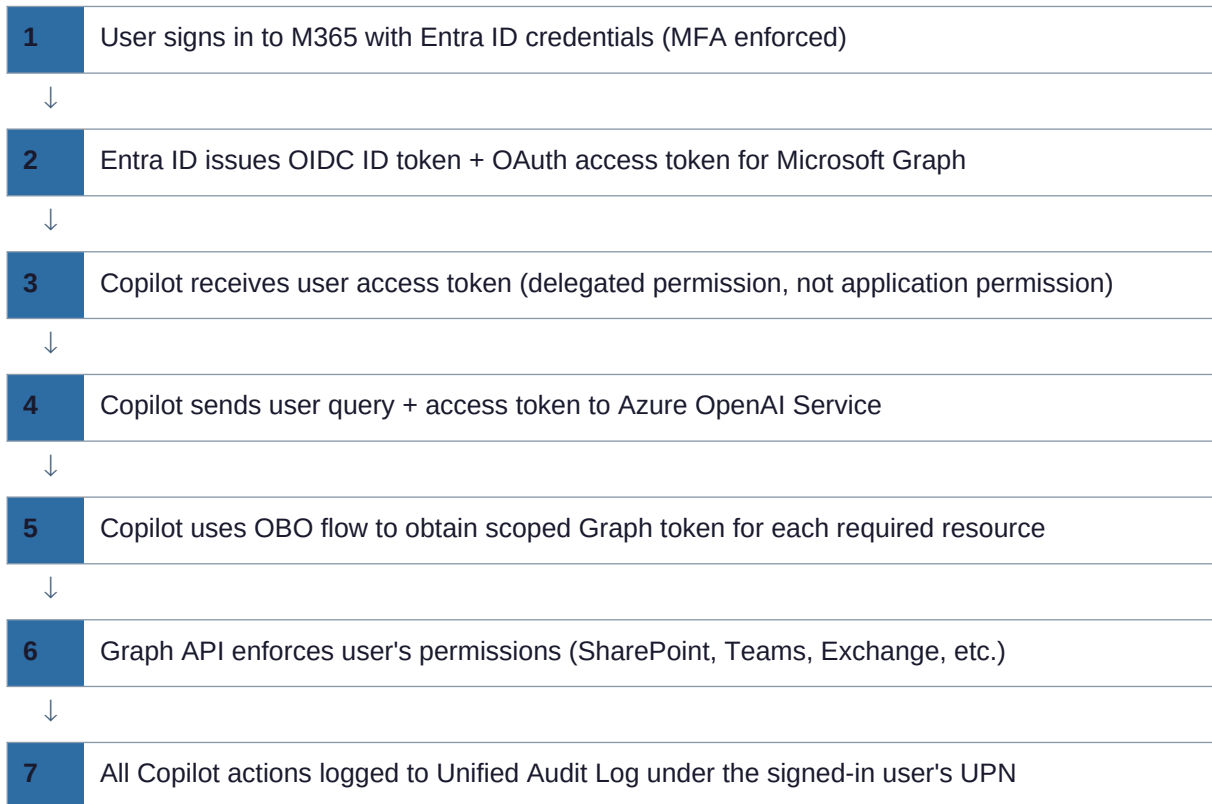
Microsoft 365 Copilot is the most deeply integrated enterprise AI platform from an identity perspective. It is built entirely on Microsoft Entra ID (formerly Azure AD), Microsoft Graph, and the Microsoft identity platform. Copilot always acts on behalf of the signed-in user, using OAuth 2.0 On-Behalf-Of (OBO) to call Microsoft Graph APIs.

Microsoft 365 Copilot — Architecture Matrix

Dimension	Detail
Architecture	Integrated into M365 SaaS; Azure-hosted; Entra ID as authoritative IdP; Graph as API layer
Authentication	Microsoft Entra ID; SAML / OIDC / Kerberos for hybrid; MFA enforced via Conditional Access
Authorization	Microsoft Graph permissions (delegated); Entra Conditional Access policies; Sensitivity Labels

Dimension	Detail
Connector Model	Microsoft Graph Connectors; Teams Message Extensions; Power Platform connectors; Plugins
Identity Propagation	Entra ID issues delegated access token; Copilot passes user's token to Graph — never service acct
Session Handling	MSAL session tokens cached client-side (MSAL.js) and server-side; CAE for real-time revocation
Token Management	Short-lived access tokens (60-90 min); refresh tokens up to 90 days; CAE extends to event-based
Governance	Microsoft Purview (DLP, sensitivity labels, retention); Compliance Manager; eDiscovery
Audit Logging	Microsoft Purview Audit (Standard / Premium); Copilot activity logs in Unified Audit Log (UAL)
Multi-Tenant Isolation	Entra tenant isolation; no cross-tenant data without explicit External Identities config

M365 Copilot OBO Flow



Why Microsoft's OBO Implementation Matters

- Access token is always delegated — not application-level (no implicit elevation)
- Copilot cannot access files the user cannot access
- Sensitivity labels enforced at Graph layer even if Copilot requests content
- CAE (Continuous Access Evaluation) revokes tokens in near-real-time on policy change
- Purview DLP policies apply to Copilot output, preventing data exfiltration

5. GitHub Copilot

GitHub Copilot operates within the GitHub ecosystem, meaning identity flows through GitHub.com or GitHub Enterprise Server (GHES) authentication. The IDE extension authenticates once via OAuth Device Flow and caches a GitHub access token. Copilot extensions (preview) allow third-party agents to integrate via the GitHub Copilot Extensions API.

GitHub Copilot — Architecture Matrix

Dimension	Detail
Architecture	IDE extension + GitHub.com backend; GHES for self-hosted; GitHub App model for org-level access
Authentication	GitHub OAuth Device Flow for IDE; SAML SSO for Enterprise; GitHub App installation tokens
Authorization	Repository-level permissions; org policy controls (enabled repos, seat assignment); GHEC enforcement
Connector Model	GitHub Copilot Extensions (GitHub Apps with Copilot capability); MCP experimental support
Identity Propagation	GitHub user identity propagated via access token; Extensions receive user token via X-GitHub-Token
Session Handling	Long-lived OAuth token stored in IDE credential store; refreshed on expiry or SAML re-auth
Token Management	Fine-grained PATs or classic tokens; GitHub App installation tokens (1 h); org-level token policies
Governance	Copilot Business / Enterprise policy: content filter, code suggestions, IP indemnification
Audit Logging	GitHub Audit Log (org/enterprise level); Copilot usage metrics; streamed to SIEM via log streaming
Multi-Tenant Isolation	Org-scoped tokens; GHES network isolation; EMU (Enterprise Managed Users) for strict control

6. Amazon Q Business

Amazon Q Business is AWS's enterprise AI assistant. It integrates with AWS IAM Identity Center (successor to SSO) as the IdP and uses data source connectors that crawl enterprise content with ACL-aware indexing, ensuring users only see results they are permitted to access.

Amazon Q Business — Architecture Matrix

Dimension	Detail
Architecture	AWS-hosted SaaS; IAM Identity Center for SSO; Amazon Kendra / Q index for retrieval
Authentication	SAML / OIDC via IAM Identity Center; MFA; federated from Okta, Entra ID, Ping
Authorization	ACL-aware document indexing; user context passed to index for permission-filtered results
Connector Model	Built-in data source connectors (S3, SharePoint, Salesforce, Jira, etc.); Lambda for custom
Identity Propagation	IAM Identity Center user identity mapped to data source ACL; Q filters results by user
Session Handling	IAM Identity Center session tokens; web experience sessions via Cognito or custom OIDC
Token Management	AWS STS short-term credentials; OIDC tokens from Identity Center; no long-lived AWS keys
Governance	AWS IAM policies; S3 bucket policies; VPC-deployed connectors for data locality
Audit Logging	AWS CloudTrail for all API calls; Q Business conversation logs to CloudWatch; S3 export
Multi-Tenant Isolation	Application-level isolation in Q; per-application IAM roles; VPC isolation for connectors

7. Atlassian Rovo

Atlassian Rovo is built on Atlassian's identity platform (Atlassian Access / Atlassian Guard) and the Atlassian Forge runtime. Rovo agents run inside Forge, which enforces permission boundaries using Atlassian's OAuth 2.0 3LO (Three-Legged OAuth) scopes.

Atlassian Rovo — Architecture Matrix

Dimension	Detail
Architecture	Atlassian cloud; Forge serverless runtime; Rovo agents as Forge apps with scoped permissions

Dimension	Detail
Authentication	Atlassian Account (SAML 2.0 SSO via Atlassian Access); Google/Microsoft identity federation
Authorization	Forge OAuth 2.0 3LO scopes; site-level admin controls; Rovo agent permission manifests
Connector Model	Forge-native connectors; Atlassian Marketplace apps; REST API integrations with OAuth 2.0
Identity Propagation	Forge context provides authenticated user's Atlassian Account ID; passed to Jira/Confluence APIs
Session Handling	Atlassian session cookies (cloud.session.token); Forge functions are stateless per invocation
Token Management	Short-lived Forge access tokens; OAuth 2.0 refresh tokens managed by Atlassian platform
Governance	Atlassian Guard (DLP, shadow IT, audit); admin console policy; IP allowlisting
Audit Logging	Atlassian Audit Log; organisation-level events; streamed to SIEM via Atlassian Access APIs
Multi-Tenant Isolation	Site-scoped Atlassian tenancy; Forge app sandbox isolation; no cross-site data access

8. ServiceNow AI Agents

ServiceNow AI Agents operate within the ServiceNow platform, using the built-in identity and access management (IAM) capabilities. ServiceNow supports SAML, OIDC, and OAuth 2.0 for SSO and API access. Agents can execute actions as the delegating user or as a configured service account, with explicit admin configuration required.

ServiceNow AI Agents — Architecture Matrix

Dimension	Detail
Architecture	ServiceNow SaaS (Now Platform); AI agents as Flows / Subflows; integration via IntegrationHub
Authentication	SAML 2.0 / OIDC SSO; Multi-Factor Auth; OAuth 2.0 for API; local auth for legacy
Authorization	RBAC with ACLs; user criteria; domain separation for multi-tenant; scripted access controls
Connector Model	IntegrationHub spokes (GitHub, Jira, Slack, etc.); MID Server for on-prem; REST API steps

Dimension	Detail
Identity Propagation	Flow context carries sys_user; delegated execution uses impersonation or OAuth OBO
Session Handling	ServiceNow session (glide_session); token-based API sessions; SAML session lifetime policies
Token Management	OAuth 2.0 client credentials or auth code; token refresh handled by OAuth entity profile
Governance	GRC (Governance, Risk, Compliance) module; security incident response; audit trail built-in
Audit Logging	sys_audit table; transaction log; integration activity log; exportable to SIEM
Multi-Tenant Isolation	Domain separation; company isolation model; scoped apps in private scope; data classification

9. Glean

Glean is an enterprise search and AI platform focused on permission-aware retrieval. It crawls enterprise data sources using OAuth service accounts and stores ACL metadata alongside indexed content. At query time, Glean filters results based on the requesting user's identity and permissions.

Glean — Architecture Matrix

Dimension	Detail
Architecture	Hosted SaaS or customer-cloud deployment (GCP/AWS); dedicated tenant environment per customer
Authentication	SSO via SAML 2.0 / OIDC (Okta, Entra ID, Google); service account for indexing crawlers
Authorization	Permission-trimmed search results; per-document ACL stored at index time; no elevation possible
Connector Model	Pre-built connectors (100+) per data source; admin configures OAuth service account per connector
Identity Propagation	User's IdP identity mapped to data source identity; ACL checked against this mapping
Session Handling	SSO session; Glean web session (JWT); token refresh via SSO provider
Token Management	Service account OAuth tokens per connector (long-lived, admin-managed); user tokens via SSO
Governance	Admin controls (data source visibility, user permissions); DLP integration; retention policies

Dimension	Detail
Audit Logging	Search audit log; document access events; admin activity log; SIEM export
Multi-Tenant Isolation	Separate tenant infrastructure; dedicated index; no cross-tenant data; VPC peering option

10. Moveworks

Moveworks is an AI platform focused on employee IT and HR automation. It connects to enterprise systems via a creator studio and plugin framework. Identity is established at employee login (SSO) and Moveworks maintains per-employee OAuth tokens to act on their behalf across connected systems.

Moveworks — Architecture Matrix

Dimension	Detail
Architecture	Hosted SaaS; deployed via enterprise chat channels (Slack, Teams); event-driven action execution
Authentication	SAML 2.0 SSO; employee identity from HRIS (Workday, SAP); OAuth 2.0 per connected system
Authorization	Employee's own permissions in each connected system; Moveworks does not elevate privileges
Connector Model	Creator Studio plugins (REST API + OAuth); pre-built integrations (ServiceNow, Jira, etc.)
Identity Propagation	Employee's OAuth token used for each system API call; token stored encrypted per employee
Session Handling	Chat session via Teams/Slack; Moveworks backend session tied to employee identity
Token Management	Per-employee OAuth tokens stored encrypted; automatic refresh; revocation on offboarding
Governance	Creator Studio guardrails; action approval workflows; admin-configured allowed operations
Audit Logging	Action audit log per employee; conversation log; integrated with SIEM via webhook
Multi-Tenant Isolation	Customer-scoped deployment; dedicated data store; no cross-customer data

Cross-Platform Comparison

Platform Comparison Summary

Platform	IdP Integration	OBO / Delegated	MCP Support	Audit Log
Google Gemini	Google Identity / SAML	Google OBO (service acct)	Via Extensions	Workspace Audit
Claude	SAML 2.0 / SCIM	MCP server OBO pattern	Native MCP	Admin Audit Log
ChatGPT Enterprise	SAML 2.0 / SCIM	GPT Action OAuth (user)	Via Actions	OpenAI Audit Log
M365 Copilot	Entra ID / OIDC	OAuth OBO (delegated)	Via Graph Connectors	Purview UAL
GitHub Copilot	GitHub / SAML EMU	User token / App token	Experimental	GitHub Audit Log
Amazon Q	IAM Identity Center	ACL-filtered retrieval	Via Lambda	CloudTrail
Atlassian Rovo	Atlassian Access	Forge 3LO OAuth	No (Forge native)	Atlassian Audit
ServiceNow	SAML / OIDC	Impersonation / OBO	Via IntegrationHub	sys_audit
Glean	SAML / OIDC	ACL-filtered results	No	Search Audit Log
Moveworks	SAML 2.0	Per-employee OAuth token	No	Action Audit Log

Key Takeaways from Industry Survey

- Microsoft 365 Copilot provides the most mature OBO (On-Behalf-Of) implementation via Entra ID
- Claude's MCP is the only open-standard protocol designed for tool integration identity propagation
- All enterprise platforms claim permission-non-elevation; implementation quality varies significantly
- Audit log completeness varies — only M365 Copilot (Purview) and ServiceNow provide full chain logging
- Multi-tenant isolation is strongest in dedicated-VPC deployments (Glean, Amazon Q Business)
- Session continuity across long conversations is an unsolved problem for most platforms